

Open Source Compliance in the Enterprise: Benefits and Risks

Open Source Compliance in the Enterprise: Benefits and Risks

Created on 2017-02-02 22:57

Published on 2017-02-09 02:58

There are several benefits to creating programs and processes that help companies and other organizations achieve open source compliance. On the flip side, there are many risks that companies face when they fail to comply with open source licenses.

In part 3 of this series on Open Source Compliance in the Enterprise, we'll cover the benefits of complying and the risks of non-compliance, as well as give an overview of common ways that companies fail to comply.

The Benefits of Open Source Compliance

Companies that maintain a steady-state compliance program often gain a technical advantage, since compliant software portfolios are easier to service, test, upgrade, and maintain. In addition, compliance activities can also help identify crucial pieces of open source that are in use across multiple products and parts of an organization, and/or are highly strategic and beneficial to that organization.

Conversely, compliance can demonstrate the costs and risks associated with using open source components, as they will go through multiple rounds of review.

A healthy compliance program can deliver major benefits when working with external communities as well. In the event of a compliance challenge, such a program can demonstrate an ongoing pattern of acting in good faith.

Finally, there are less common ways in which companies benefit from strong open source compliance practices. For example, a well-founded compliance program can help a company be prepared for possible acquisition, sale, or new product or service release, where open source compliance assurance is a mandatory practice before the completion of such transactions. Furthermore, there is

the added advantage of verifiable compliance in dealing with OEMs and downstream vendors.

Common Compliance Failures

- Throughout software development, errors and limitations in processes can lead to open source compliance failures. Examples include:
- Failure to provide a proper attribution notice, a license notice, or a copyright notice
- Making inappropriate or misleading statements in the product documentation or advertisement material
- Failure to provide the source code and build scripts
- Failure to provide a written notice to users on open source software included in the product and how to download source code.

Accidental admixture of proprietary and open source intellectual property (IP) can also arise during the software development process leading to license compliance issues. We'll cover these in detail in the next article.

The Risks of Non-Compliance

License compliance problems are typically less damaging than intellectual property problems. This is because IP failures may result in companies being forced to release proprietary source code under an open source license, thus losing control of their (presumably) high-value intellectual property and diminishing their capability to differentiate in the marketplace.

Other risks of license compliance and IP failures include:

- An injunction preventing a company from shipping the product until the compliance issue has been resolved
- Support or customer service headaches as a result of version mismatches (as a result of people calling or emailing the support hotline and inquiring about source code releases).
- A requirement to distribute proprietary source code that corresponds to the binaries in question under an open source license (depending on the specific case)
- A significant re-engineering effort to eliminate the compliance issues
- Embarrassment with customers, distributors, third party proprietary software suppliers and an open source community.

In the past few years, we have witnessed several cases of non-compliance that made their way to the public eye. Increasingly, the legal disposition towards non-compliance has lessons to teach open source professionals — lessons that we will explore in future articles.

The following is adapted from "Open Source Compliance in the Enterprise" published by The Linux Foundation (free e-book download), a complete guide to creating compliance processes and policies for your organization.

Original post appeared on Linux.com.
